CS-E4740 - Federated Learning

L6 - Legal Frameworks for FL

Diana Pfau

Spring 2026

Calendar **Glossary** **Book** **GitHub**

Learning goals

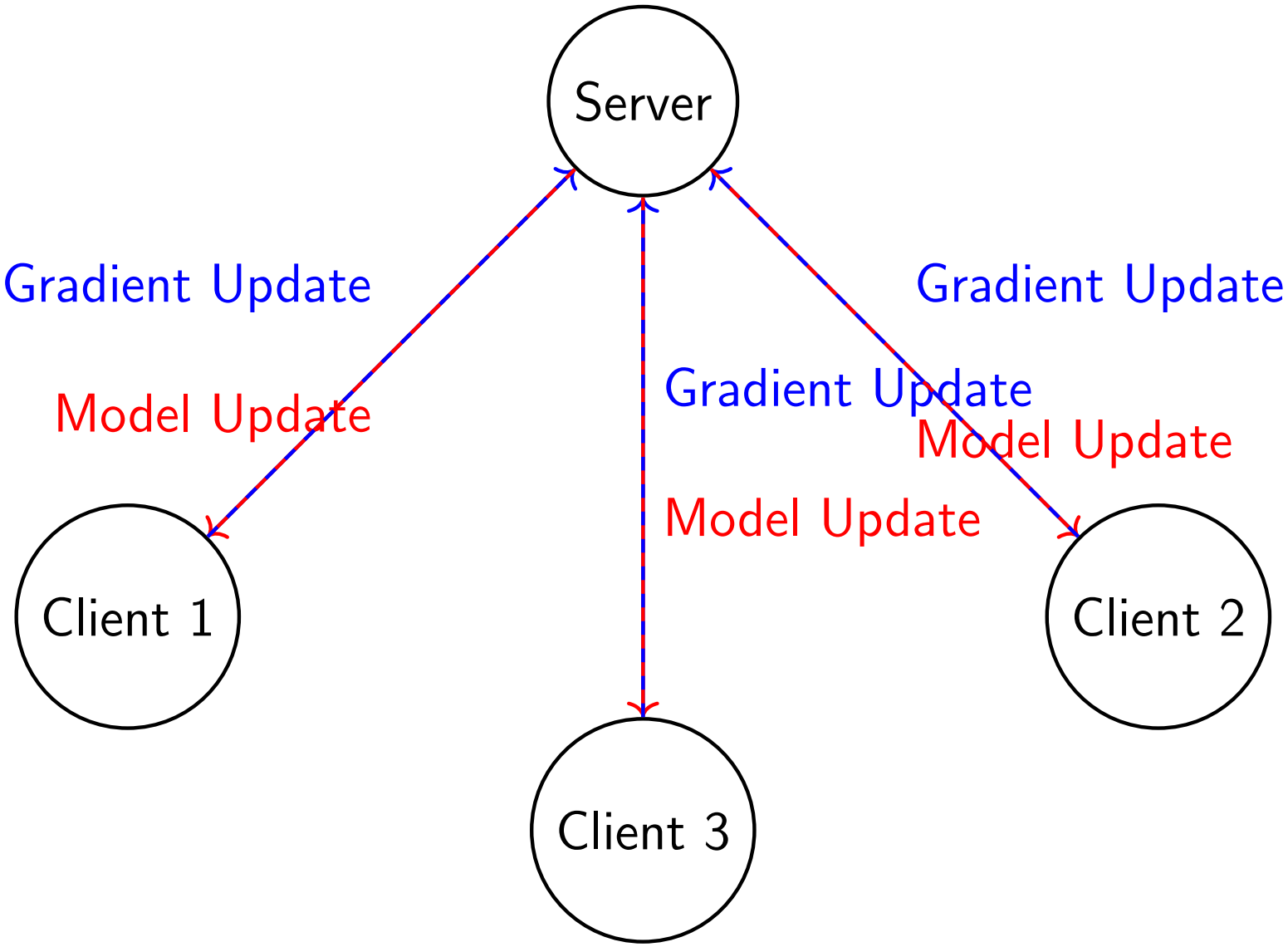
After this lecture you should be able to:

- provide an intuition on when the general data protection regulation (GDPR) or the AI Act apply
- List the requirements for when the right to explanation applies under the GDPR
- Determine whether an AI system is high risk under the AI act

Outline

- Privacy and FL
- Overview EU Digital Regulation
- the GDPR
- the AI Act
- Social Media Platforms

Federated Learning Network



FL and Privacy

- FL was introduced by Google in 2017 as a privacy friendly method
- However, this does not mean that Privacy evaluations are not necessary
- local models still utilise personal data and fall under the GDPR normally
- Gradients can still be personal data when they can be used to reconstruct personal data
- model updates can also be considered data if they can be used for reconstruction of data

Why is Privacy important?

- safeguards other rights - freedom of thought, speech, religion
- safeguards individual autonomy and dignity
- protection from fraud or identity theft
- safeguards from discrimination
- Margulis(1977): privacy as a selective control over transactions between self and others, enhances autonomy and reduces vulnerability
- Brandeis and Warren: "Right to be left alone"

Overview of EU Digital Regulation

Fundamental Rights & Data Protection

- GDPR
- ePrivacy Directive
- Law Enforcement Directive (LED)

Digital Governance (Internal Market Basis)

- Digital Markets Act (DMA)
- Digital Services Act (DSA)
- AI Act
- Data Act

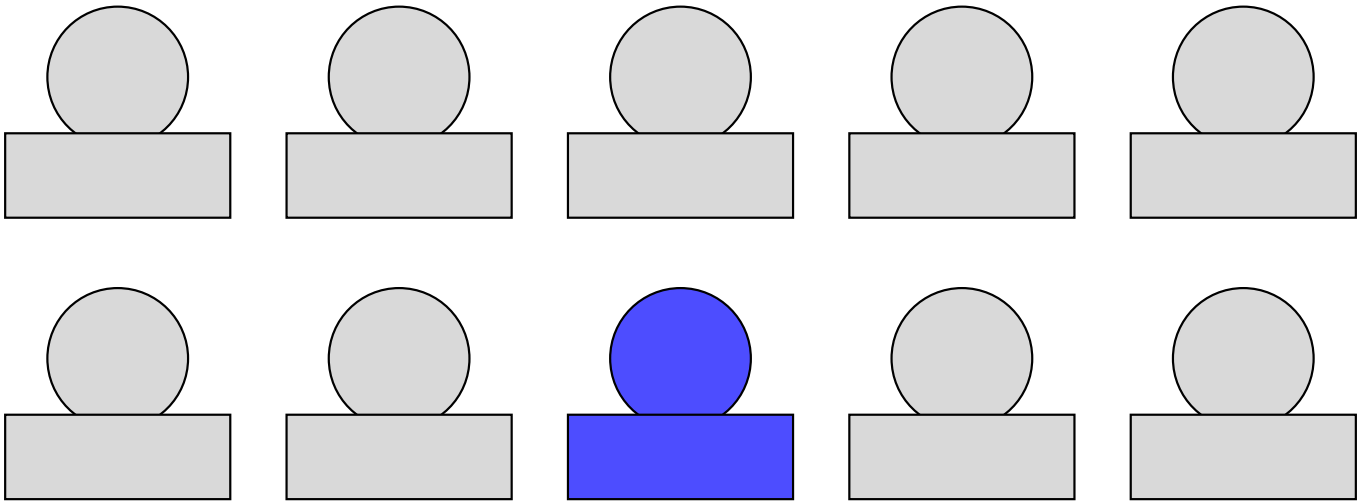
General Data Protection Regulation

- applies to personal data processing with the EU
- lays down rights of persons towards the processing of their information
- lays down principles for processing of personal data

Personal data

- = any information relating to an identified or identifiable person
- this also means that anonymous data that makes it impossible to identify a person is not personal data - but what is the odds that anonymity is guaranteed?
- to determine whether a natural person is identifiable, account should be taken of al means reasonably likely to be used, such as singling out by the controller or another person to identify the natural person.

personal data - what is it?



personal data is defined as any data that relates to an identified or identifiable individual. Note : singling out a person might be enough.

Can you identify personal data?

- Name?
- Health record?
- company email address: firstname.lastname@company.com?
- IP address?
- written notes about a students performance?

Overview GDPR

- Chapter I – General Provisions (Arts. 1–4)
  - Art.1-3 define when and to what the GDPR applies
  - Art. 4 gives definitions of the terms used in the law
- Chapter II – Principles (Arts. 5–11)
  - Article 5- principles of processing
  - Article 6 - legal basis of processing

Overview GDPR

- Chapter III – Rights of the Data Subject (Arts. 12–23)
  - Art. 12-14 Rights to information of the data subject
  - Art. 15 Right to access
  - Art. 16 Right to rectification
  - Art. 17 Right to erasure
  - Art. 18 Right to restriction of processing
  - Art. 20 Right to data portability
  - Art. 21 Right to object
  - Art. 22 Automated individual decision-making
- Chapter IV – Controller and Processor (Arts. 24–43)
- ...

Principles of Processing

- lawfulness, fairness, transparency
- purpose limitation - data shall be collected only for predefined, specific purposes
- data minimisation- only adequate, relevant, necessary data for the purpose shall be collected
- storage limitation - data shall not be stored for longer than necessary
- accuracy
- integrity and confidentiality

Legal basis for processing Art.6

- consent of the data subject
- necessary for the performance of a contract
- necessary for compliance with legal obligations
- (...)

GDPR - Special categories of data (exception to personal data!)

- =personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, sexual orientation, biometric data and data cocerning health
- Art.9 (1)- general prohibition of processing of such data
- Art. 9 (2) exceptions:
  - explicit consent
  - to fulfill duties in employment relationship and social security
  - processing relation to personal data that is manifestly made public by the data subject
  - (...)

Explicit consent (see consent Art.7)

- consent means any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her
- has to be based on information given to data subject
- consent has to be free - cannot be coerced
- it has to be specific
- pre-ticked boxes do not fulfill this requirement!
- "explicit" refers to the manner in which consent is given- e.g. signing a consent form

Individual automated decision-making

Definition:
"The data subject shall have the right not to be subject to a **decision based solely on automated processing, including profiling**, which produces **legal effects** concerning him or her or **similarly significantly affects** him or her."

- What is a decision based solely on automated processing?
- what are legal or similar effects?
- what is profiling?

Individual automated decision-making

- "solely automated processing"
  - no human involvement in the decision making
  - no marginal human involvement in decision making
  - Examples: automated credit decisions, automated recruitment
- "decisions producing legal effects"
  - =decisions that affect the legal rights of a person
  - examples: cancellation of a contract, entitlement or denial of a particular social benefit, refused admission to a country or denial of citizenship)

Individual automated decision-making

- "similarly significant effects"
  must have potential to:
  - significantly affect the circumstanes, behaviour or choices of the individuals concerned
  - have a prolonged or permanent impact on the data subject, or
  - as its most extreme, lead to the exclusion or discrimination of individuals
- examples: elligibility to credit, access to health services, employment opportunity, education access

Example: Online advertising as automated decision-making

online advertisement can fall under Art. 22 depending on:

- intrusiveness of profiling, including tracking of individuals across different websites, devices, services
- expectations and wishes of the individuals concerned
- the way advert is delivered
- using knowledge of the vulnerabilities of data subject targeted

General Data Protection Regulation -profiling

- profiling= any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, e.g. analyse or predict aspects of a person

Right to explanation

The right to explanation is derived from Art.22 together with information and access rights

- It means where Art. 22(1) is fulfilled, you **have a right** to know about the existence of such decision making and meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.
- underlying idea: The data subject has a right to understand the decisions made about him or her.

Right to explanation- based on automated decision-making

- Explanations need to fit the data subject - they need to align with the previous knowledge of the person subjected to them
- Explanations need to be easily understandable, transparent
- explanations need give a clear understanding of how a specific decision was reached

Dun & Bradstreet Case: Background

- **Case:** In an Austrian case, a mobile phone operator had refused a customer's wish to conclude a contract worth 10€ per month due to insufficient credit. This was based on an automated credit assessment provided by Dun & Bradstreet. The data subject rejected the accuracy and legality of this assessment.
- **GDPR violation:** An Austrian court found that D&B breached the GDPR by failing to provide the customer with "meaningful information about the logic involved" in the automated decision.
- **Referral to CJEU:** The Austrian court asked the Court of Justice of the European Union (CJEU) to clarify the extent of the right to explanation in automated decision-making and how this interacts with trade secret protection.

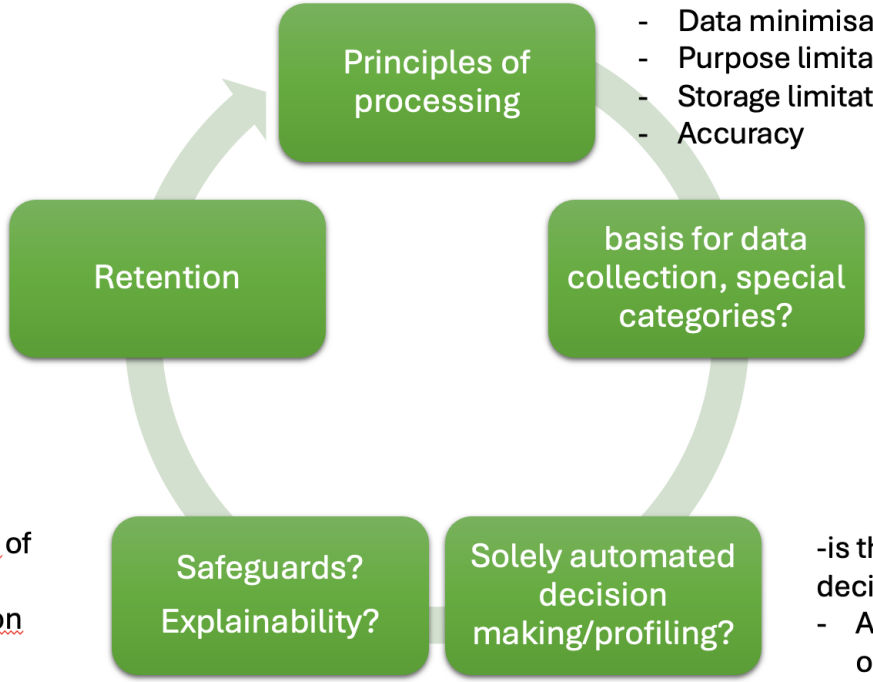
Dun & Bradstreet Case: CJEU Ruling

- **CJEU ruling — Key principles:**
  - Controllers must describe the actual procedure and principles used so that the data subject understands which personal data were used and how.
  - It may be appropriate to explain how variations in personal data would affect the outcome (counterfactuals).
  - Merely disclosing the algorithm itself is not a sufficiently clear explanation.
  - Where information involves trade secrets or third-party protected data, it must be provided to the supervisory authority or court to balance the rights at issue.
- **Outcome:** The judgment confirms that data subjects are entitled to an explanation enabling them to understand and challenge automated decisions that affect them.

Explainability Methods (ICO Guidance)

Method	Pros	Cons
SHAP / LIME (Surrogate Models)	– Model-agnostic – Local explanations – Feature importance scores	– Approximation only – Can be unstable – Computationally intensive
Counterfactual Explanations	– Intuitive ("what if?") – Action-guiding – GDPR-friendly for decisions	– May be unrealistic – Multiple possible results – Hard to compute in complex models
Feature Importance (Global)	– Simple overview – Easy to visualise – Shows main drivers	– No individual reasoning – Can hide bias – Oversimplifies complex models

How one could think of the lifecycle of Ai



- Lawful, fair, transparent,
- Data minimisation
- Purpose limitation
- Storage limitation
- Accuracy

Consent, performance of a contract ,legitimate interest, public interest, compliance with laws, protection vital interests

-is there a solely automated decision making process?

- Are we evaluating aspects of a person?
- What are the effects?

-human intervention
-right to express their point of view
Right to contest the decision

- How can we delete data?
- For how long do we have to and can we keep it?

Connection FL?

- It is not ultimately settled how to best explain automated decison-making based on FL, because the model is an aggregate of updates from multiple parties
- the more transparent your models are, the easier explainability becomes, pay attention to how you can explain your FL system´s decisions early on
- Note: Explainability is necessary where Art. 22 applies. If you cannot explain your model, ensure Human involvement and that the human makes the final decision based on your model outcome instead!

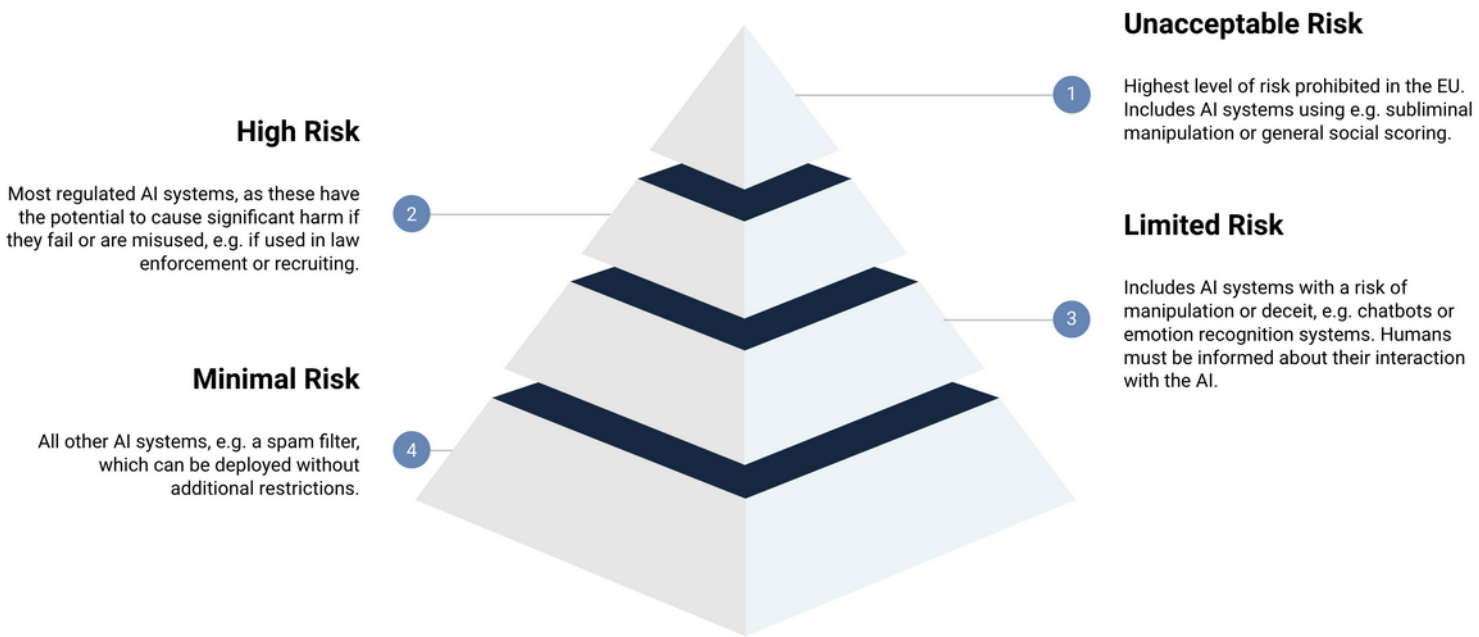
Main takeaways so far

- the GDPR applies to processing of personal data and special categories of data in the Eu
- you always need a legal basis for processing such as consent, necessity for the performance of a contract,...
- the principles of processing apply to ALL processing of personal data under the GDPR
- Your rights include the right to access, information, rectification, erasure, etc. In order to use those you need to be active as a data subject
- where solely automated decision-making is used, you need to assess whether it falls under Art.22 and prepare to explain the output of your model

The AI Act

- Applies to AI systems and assigns risk
- Lays down additional requirements for high-risk AI systems and General purpose AI
- The AI Act can apply simultaneously with the GDPR, they do not exclude each other!!

AI Act Risk categories



https://www.trail-ml.com/blog/eu-ai-act-how-risk-is-classified

AI Act High risk Systems

- **Definition:** An AI system is high-risk if it **poses significant risks to health, safety, or fundamental rights**.
- **1. High-Risk Use Cases (Annex III)**
  - Critical infrastructure (transport, energy systems)
  - Education and vocational training (grading, access)
  - Employment and worker management (recruitment, promotion)
  - Essential services (credit scoring, insurance, social benefits)
  - Law enforcement (predictive policing, facial recognition)
  - Migration, asylum, border control (visa or deportation decisions)
  - Administration of justice (AI-assisted court decisions)

High Risk AI systems

- **2. System Characteristics**
  - Significantly affects rights or safety of individuals
  - Lacks transparency or human oversight
  - Used for profiling or automated decisions with legal/significant effects

Explainability AI Act under Art. 86

The right to explanation applies to High-risk AI systems and requires for the deployer to provide "clear and meaningful explanations of the role of the Ai system in the decision-making procedure and the main elements fo the decision taken.

- **Explainability Requirements:**
  - Users and providers should ensure AI decisions are **understandable and interpretable**.
  - Documentation and procedures should allow **traceability of decisions**.
  - Helps align AI behavior with **transparency, accountability, and fundamental rights**.

AI Act- requirements high risk AI systems

- Risk management- evaluation of possibly arising risks and their mitigation has to be documented on an ongoing basis
- Data and Data Governance- training, validation and testing data shall be subject to data governance and management practices- e.g. design choices shall be documented and justified, origin of collected data needs to be documented, data preprocessing, assessment of quality of data required, etc.
- Importantly: special categories may exceptionally be processed for bias detection where no other measure is effective to prevent bias
- Technical Documentation-description of AI system, intended purpose, description of elements of the AI system, its role in a product, description about the monitoring, functioning and control of the AI system (...)

Case example- credit scoring

We wish to implement a credit scoring system to determine whether person A should get a loan for buying a house

- to do so, which data should we collect?
- which law applies? GDPR or AI act?
- is this an automated decision?

Case example credit scoring

- Data minimisation: only data necessary for the purpose of determining whether the person is creditworthy may be collected!
- Credit scoring falls both: under the AI Act and the GDPR

Comparison: AI Act vs GDPR

Aspect	GDPR	AI Act
Scope	Applies to processing of personal data within EU or by controllers/processors targeting EU citizens	Applies to all AI systems placed on the EU market or used within the EU, with risk-based categorization
Focus	Protection of personal data and privacy, data subject rights, lawful processing	Ensuring trustworthy AI, risk management, transparency, human oversight, prohibited practices
Risk Approach	General principles, no explicit risk categorization	Explicit risk-based approach: unacceptable, high, limited, minimal risk AI systems
Obligations	Data protection by design, lawful basis, transparency, accountability, data subject rights	Compliance documentation, risk assessment, data governance, human oversight, transparency, conformity assessment

Main takeaways so far

- The AI Act and the GDPR can apply simultaneously
- The AI Act applies to all AI systems, but mostly defines additional requirements for high-risk AI focusing on documentation of design choices and risk monitoring
- The Right to explanation exists both in the GDPR and the AI Act

Social Media Platforms & Privacy Concerns

Social Media Platforms have been critiqued regularly regarding privacy and concerns regarding mental health. Here a few concerns:

- Major platforms collect vast amounts of data to be used to power recommender system, targeted ads, to nudge persons into potentially unfavourable behaviour.
- Platforms power constant surveillance of online activities
- Platforms operate largely opaquely and make it difficult for users to understand how recommender systems work, how their data is used and how to make use of their rights
- There is evidence of social media use in teenagers fueling anxiety and depression
- Social media platforms can be a hub for misinformation and hatespeech, especially in the absence of functioning content moderation

Social Media Platforms and Digital Regulation

Regulators have been trying to curb negative impacts of Social media by implementing several legislative tools. Now several instruments apply to (big) social media platforms:

- GDPR: for processing of personal data and fairness of processing
- AI Act: for the use of AI systems (e.g. recommender systems)
- Digital Services Act: for content moderation or addictive features
- Digital Markets Act: specifically targets large online platforms and prevent them from misusing market power

Major GDPR Fines Against Meta

- EU-US Data Transfers (2023): €1.2 Billion
- Instagram Children's Privacy (2022): €405 Million
- Facebook Behavioral Ads (2023): €210 Million
- Instagram Behavioral Ads (2023): €180 Million
- Data Scraping Breach (2022): €265 Million
- WhatsApp Transparency (2021): €225 Million
- 2018 Security Breach (2024): €251 Million
- Plain-text Password Storage (2024): €91 Million
- Historical Data Breaches (2022): €17 Million

Total Cumulative Fines: Over €2.8 Billion

Eu investigations into TikTok

- The EU found TikTok breaches the Digital Services Act
- The Digital service act rules on platform design were violated due to:
  - overall addictive design
  - highly personalised recommender system
  - infinite scroll
  - pushnotifications
  - autoplay
  - potential fine for breaches is 6% of the worldwide turnover

EU - TikTok and Meta

- both companies were investigated for violations of DSA
- Data access for researchers: both were found to make it extra budensom for researchers to get access to data for research purposes
- Meta Products Facebook and Instagram both make "notice and action" burdensome for users and are using darkpatterns making it difficult for users to report illegal content
- Meta Products Facebook and Instagram do not allow users to challenge content moderation decisions appropriately

Conclusions

We have seen that:

- The GDPR applies to the processing of personal data and provides a wide range of rights and duties
- The AI Act applies to AI systems and categorises such systems in accordance with their associated risks
- Social Media Platforms create signficant risks and are regulated from several different angles